JÖNKÖPING UNIVERSITY
School of Engineering

LABORATION 1 – INTRODUKTION TILL NÄTVERKSSÄKERHET

Första laborationen i kursen *Nätverkssäkerhet* tar upp grunderna för hur nätverk kan säkras upp. Vi börjar med enkel penetrationstestning i form av rekognans. Sedan går vi igenom enkla åtgärder i form av att säkra upp kontroll- och management-planet på nätverksenheter.

Syftet med laborationen är att studenten ska bekanta sig med de vanligaste verktygen för att göra portskanningar och sårbarhetsanalyser, samt testa på verktyg för att säkra upp nätverksenheter. Laborationsdelen i kursen examinerar hela eller delar av följande lärandemål:

- *visa färdighet i planering, design och implementering av nätverkssäkerhetslösningar för små och medelstora nätverk*
- *visa insikt i etiska aspekter inom nätverksteknik med avseende på loggning, avlyssning, penetrationstestning och liknande*
- *visa förmåga till ett säkerhetsmedvetet förhållningssätt vid planering, design och implementation av lokala nätverk*

1 Uppgift

Uppgiften förutsätter deltagande på veckans föreläsning, samt genomläsning av kapitel 1 - 7 innan laborationen påbörjas. Labbhäftet rekommenderas som referenslitteratur. Laborationen är indelad i två delar:

1. Utför enkel penetrationstestning
2. Säkra upp kontroll- och management-planet

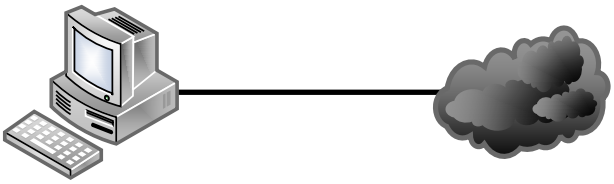
I labbrapporten ska gruppen (max 3 personer) bevisa att de har utfört alla fetmarkerade uppgifter i gula rutor, detta kan exempelvis vara med hjälp av skärmbilder, förklaringar, konfiguration och svar på frågor. Om inget är specificerat väljer ni själva hur ni vill bevisa att ni har utfört uppgiften. Om laborationen utförs utanför ordinarie laborationspass är det tillåtet att arbeta och lämna in enskilt. Säkerställ att skärmbilder är beskurna på ett bra sätt, inte för mycket och inte för lite. Såväl skärmbilder som täcker hela skärmen som skärmbilder där man endast ser en enstaka rad duger inte.

1.1 Utför en enkel penetrationstestning

Första steget när ett nätverk ska säkras upp bör alltid vara en riskhanteringsprocess. Vi hoppar dock över det steget och börjar direkt med att testa säkerheten på ett befintligt nätverk.

Rekognans

Rekognans innebär att vi tar reda på användbar information om en organisation och dess nätverk. Denna del av laborationen kräver

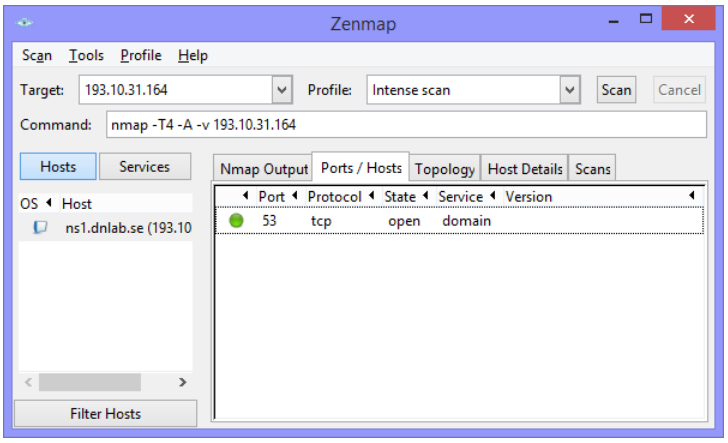


endast en labbdator kopplad till Internet. Nätverket som ska undersökas idag är labbnätverket *DNLAB*, den informationen som finns sedan tidigare är att organisationen äger domännamnet dnlab.se och att namnserver för dnlab.se-zonen är 193.10.31.164.

1. Använd valfri WHOIS-tjänst för att ta reda på när domännamnet skapades, vem som är registrar samt om det finns några IPv6-adresser kopplade till domännamnet. Hittar du någon mer information som kan vara användbar i rekognans-syfte? Vilka spann av publika adresser är kopplade till domänen? Hitta organisationens IPv4- och IPv6-spann i RIPE

Portskanning

Nu har lite bakgrundsinformation samlats in om nätverket, och nu är det dags att gå vidare i rekognansen med en portskanning. Det vanligaste verktyget för portskanning är Nmap (Network Mapper), läs gärna ingående om verktyget här: https://nmap.org/book/toc.html. Installera det grafiska verktyget Zenmap på din labbdator (Zenmap finns förinstallerat om du inte har valt en vanilla-installation).



OBS: NOTERA ATT PORTSKANNING KAN VARA OLAGLIGT I VISSA FALL, OCH ÄVEN BRYTA MOT REGLERNA HOS DIN INTERNETLEVERANTÖR. DETTA STEG FÅR DÄRFÖR ENDAST UTFÖRAS I LABORATIONSSAL ENLIGT DE FÖRESKRIFTER SOM FINNS I LABORATIONEN.

Ni har nu listat ut att ett utav nätverken som DNLAB innehar är 193.10.31.160/27. Ni ska nu genomföra en portskanning.

2. Med Nmap ska en ”Intense scan” utföras med kommandot *nmap -T4 -A -v* mot nätverket 193.10.31.0/24. Förklara i er rapport vad respektive inställning (-T4 -A -v) innebär, och inkludera en sammanställning (t.ex. skärmbild) över de öppna tjänster som verktyget har hittat. Förklara dessutom varför det är viktigt att ha tillstånd av exempelvis en IT-ansvarig innan man påbörjar penetrationstestning av ett nätverk.

Nmap försöker även lista ut vilken typ av enhet som finns bakom respektive IP-adress, samt vilken variant och version av respektive tjänst som är tillgänglig.

3. Redogör för vilka tjänster som körs på nätverket, och eventuella detaljer om respektive tjänst. Om det finns många tjänster kan du välja ut ett par som ser extra intressanta ut. Är det någon enhet eller tjänst som sticker ut? Ge minst två förslag på hur man kan undvika och/eller minska risken för att eventuella sårbarheter utnyttjas. Är det någon tjänst som har kända sårbarheter (Common Vulnerabilities and Exposures, CVE)?

En portskanning ger en bra överblick över de enheter som finns på ett nätverk, och vilka tjänster som körs. I vissa fall räcker den informationen för att hitta en undangömd webbserver, eller för att kunna hitta en tjänst som kör standard-lösenord. Alla tjänster är dock inte nåbara direkt via sin IP-adress utan

måste anropas via sitt FQDN (fully qualified domain name), detta gäller exempelvis för många molntjänster. Mer avancerade sökningar inkluderar därför också såkallad *subdomain discovery* som kan göras via sidor och verktyg som DNS Dumpster, Sublist3r, SubBrute, DNSRecon, etc. Enligt egen erfarenhet är Pentest-Tools verktyg för detta en utav de effektivaste gratistjänsterna för att hitta mest information. Vid en snabb överblick verkar det dock som att alla tjänster i just detta nätverk svarar direkt på sin IP-adress.

Installation av Kali Linux

När vi börjar använda mer avancerade metoder för penetrationstestning är det bäst att gå över till ett Linux-baserat operativsystem då de flesta (och bästa) verktygen finns där. I denna laboration ska vi använda oss av Kali Linux som är en skräddarsydd distribution för penetrationstestning. Ett tips är att använda de färdiga VirtualBox-maskinerna som finns tillgängliga, notera dock att en ny MAC-adress måste skapas då det annars blir IP-adresskonflikt i labbet.

4. Ladda ner Kali Linux (VM) på https://www.kali.org/downloads/ och installera det som en virtuell maskin i VirtualBox (undvik Hyper-V). Ta reda på hur man gör motsvarande bryggat läge, och ställ in en av dina publika adresser på den virtuella maskinen. Ta en skärmbild av kommandot "ip address". Kali Linux kommer användas i flera laborationer i kursen framöver.

I Kali Linux finns en stor variation med verktyg för att penetrationstesta.

Sårbarhetsanalys (frivillig del, men läs gärna)

Tidigare år har detta strulat och tagit väldigt lång tid, och jag har därför valt att ta bort den som obligatorisk. Problemet är att OpenVAS måste ladda ned alla kända sårbarheter i världen (typ), och därför tar flertalet timmar att installera. Om du ändå vill göra den delen av laborationen (vilket är helt valfritt) följer du instruktionerna nedan, annars räcker det att läsa igenom instruktionerna och sedan påbörja del 1.2.

Nästa steg i rekognansen är att utföra en sårbarhetsanalys. För sårbarhetsanalyser finns ett verktyg som heter OpenVAS (numera Greenbone Vulnerability Manager, gvmd) som bygger på Nessus som är den mest använda sårbarhetsskannern i världen.

Verktyget finns inte med som standard på Kali Linux, för att installerade det, följ denna guide: https://www.kali.org/penetration-testing/openvas-vulnerability-scanning/ (OBS: Om ni inte planerar för en lång kafferast rekommenderas ej *apt-get dist-upgrade* som eventuellt uppgraderar hela operativsystemet). OpenVAS har precis kommit med en uppdatering, och kommer framöver att kallas för *Greenbone Vulnerability Management* eller *gvm*. Kör följande kommando för att starta igång installationen:

```
root@kali:~# gvm-setup
```

Detta kommer ta lite tid eftersom alla kända sårbarheter i världen (typ) ska laddas in i systemet, vilket tar upp till fyra timmar. Under installationen kan du påbörja labbavsnitt 1.2 som inte bygger på att denna del är färdig. När installationen är färdig; se till att spara lösenordet som genereras i slutet av installationen. Starta igång tjänsten med:

```
root@kali:~# gvm-start
```

Via den virtuella maskinen ska vi nu kunna nå webbgränssnittet på https://127.0.0.1:9392 i den virtuella maskinen, eller från din labbdator via https://{din publika adress}:9392.

Sätt i gång en sårbarhetsskanning mot 193.10.31.82 under *Scans -> Tasks -> New Task.*

1.2 Penetrationstestning

Nästa steg i penetrationstestning är att testa om sårbarheterna går att utnyttja. Ett vanligt verktyg för detta är Metasploit. För att testa på riktigt ska vi ladda ned en VM som är förberedd med kända sårbarheter. Metasploit**able** är en förberedd miljö som lämpar sig väl för denna typ av tester. Ladda ned Metasploitable här: https://sourceforge.net/projects/metasploitable/files/Metasploitable2/ och följ instruktionerna för att konfigurera miljön på rätt sätt i VirtualBox: https://www.geeksforgeeks.org/how-to-install-metasploitable-2-in-virtualbox/

Lägg in ett extra nätverkskort i både Kali och Metasploitable som är satt som ”Internal Network”, sätt dessa två interface i samma nätverk, t.ex. 10.0.2.10 och 10.0.2.11. Säkerställ att de kan nå varandra.

OBS: NU ÄR DET DAGS ATT UTFÖRA PENETRATIONSTESTNING. UTFÖR ENDAST DENNA TYP AV TESTER PÅ ENHETER OCH NÄTVERK SOM NI SJÄLV STYR ÖVER ELLER SOM NI HAR FÅTT TILLÅTELSE ATT TESTA. TESTA ALDRIG UT MOT INTERNET DÅ DETTA KAN VARA OLAGLIGT.

I Kali Linux ska vi använda *Metasploit Framework (MSF)* för att köra en exploit (på klarspråk: hacka en server). Metasploit körs effektivast i terminalvarianten *msfconsole*. En känd sårbarhet är i mjukvaran för VSFTPD 2.3.4 som körs på Metasploitable. I *msfconsole* skriver ni:

```
msf5 > use exploit/unix/ftp/vsftpd_234_backdoor
msf5 exploit (unix/ftp/vsftpd_234_backdoor) > set rhosts {IP-ADRESS PÅ METASPLOITABLE-VM}
msf5 exploit (unix/ftp/vsftpd_234_backdoor) > run
```

Om allt lyckades har du nu fått root-behörighet(**!**) till servern, detta eftersom VSFTPD körs med användaren root (inte best-practice). Du kan verifiera detta genom att skriva **whoami** samt verifiera att du styr servern genom att kontrollera IP-adressen med **ip addr**. Skapa en fil för att bevisa att du har lyckats hacka servern, till exempel med **touch** ***gruppX*** (ersätt X med era namn). Fantasin sätter bara gränsen för vad du nu kan göra med servern.

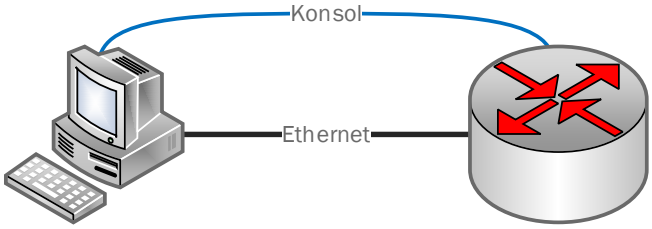
5. **Ta en skärmbild som bevisar att ni har hackat servern, samt att filen är skapad (t.ex med** ls**)**

Nu är du färdig med första halvan av laborationen, del 2 följer på nästa sida.

1.3 Del 2: Säkra upp kontrollplanet

Alla enheter bör givetvis säkras upp på olika sätt. Denna vecka börjar vi med att säkra upp nätverksinfrastrukturen när det gäller routrar. Som vi har gått igenom innan kan man dela in en router i tre konceptuella plan.

För att utföra denna labb ska vi koppla in oss i en router med stöd för avancerade säkerhetsfunktioner t.ex. Cisco 2901 (Cisco 2811 har inte detta stöd i labbet), det fungerar även att starta igång en router i GNS3 med dessa funktioner (t.ex. 7200-serien). Förutom en konsolkoppling ska ni även sätta upp ett lokalt nätverk i spannet 10.1.2.0/24 där routern och din labbdator är kopplade.



Vi börjar med att säkra upp kontrollplanet (Control Plane, CoP), här hanteras bland annat all trafik som går till routern (inte genom), t.ex. routinguppdateringar och annan trafik som skickas mellan routrar. Eftersom denna trafik går till routern måste den processeras av enhetens CPU, därför är attacker mot CoP vanliga vid olika typer av Denial of Service (DoS)-attacker mot nätverk. Vi ska därför börja med att begränsa den trafiken som får skickas till CoP med en teknik som heter Control Plane Policing (CoPP).

6. Använd veckans föreläsningsunderlag för att ta reda på hur man begränsar ICMP-trafik mot CoP. Sätt gränsen på en rimlig nivå för att man ska kunna testa ping-paket med vanlig storlek utan avbrott. Bevisa med skärmbild att för många stora ping-paket stoppas av CoPP.

En mer finkalibrerad variant av CoPP är Control Plane Protection (CPPr), denna variant ingår inte i denna laboration.

En viktig uppgift för routrar är att hantera routingtabellen och de routingprotokoll som används för att modifiera routingtabellen.

7. Ta reda på hur man säkrar upp routinguppdateringar med SHA-256 i OSPF, skriv i rapporten vilka kommandon man använder för att utföra detta. Detta behöver inte tillämpas på enheten.

Om ni ändå vill testa och om enheten inte verkar stödja stark kryptering kan ni behöva aktivera avancerade säkerhetsfunktioner på enheten, detta görs med kommandot license boot module c2900 technology-package securityk9**, spara och starta om enheten, skriv in** license accept end user agreement**, spara och starta om enheten igen.**

1.4 Säkra upp management-planet

Management-planet (MaP) är tekniskt sett ett delplan till kontroll-planet eftersom all management-trafik går via kontroll-planet. Management-trafik är till exempel NTP, SSH, Syslog, SNMP, CDP, etc. Eftersom det är många olika protokoll finns det också många attackvektorer att hantera. En stor del av säkerhetsfunktionerna här har med användarhantering och behörigheter att göra. Första steget är givetvis att säkra upp fjärrinloggningarna genom att endast köra krypterad kommunikation, d.v.s. SSH (Secure Shell).

8. Sätt i gång SSH, och ställ in att endast version 2.0 får köras. Bevisa med en skärmbild att SSH version 2.0 körs (show ip ssh). Användarkontot som skapas ska ha högsta behörighetsnivå och använda SCRYPT (stöds inte på alla enheter) för att kryptera lösenordet.

Ett problem är att användare som nu loggar in har full behörighet. Detta är bra för en administratörsanvändare som ska ha full tillgång till allt. I en vanlig nätverksmiljö är det dock vanligt att man har olika behörigheter, exempelvis att helpdesk får köra show-kommandon, men inte ändra IP-adresser. För att göra detta ska vi skapa *parser views* som är en typ av RBAC (Role-Based Access Control). Parser views kan endast köras på enheter som har aktiverat AAA-funktioner.

9. Aktivera AAA och förklara vad som händer med enheten när detta är gjort (notera att man bör vara försiktig med detta i en produktionsmiljö).

Nästa steg är att skapa olika views för olika grupper av användare.

10. Skapa en view för ”helpdesk” som har tillgång till alla kommandon som börjar med ”show ip”, övriga kommandon ska inte vara tillåtna. Skapa även en view som heter ”tech” och som endast har behörighet att köra ”show version”. Skapa en superview med namnet ”SUPERHELPDESK” som kombinerar både helpdesk samt tech.

Det är inte hållbart att implementera autentiserings- och behörighetslösningar på varje enskild enhet. I stora miljöer aktiverar man ofta någon typ av centraliserad AAA-lösning för detta. Vi ska dock börja med att aktivera *authentication* och *authorization* lokalt på enheten. Eftersom AAA redan är aktiverat behöver vi inte börja med det.

11. Ställ in AAA Authentication att som standard först testa autentisering via den lokala användardatabasen (med skiftlägeskänsligt läge, *local-case*), och om detta misslyckas använda enable-lösenordet. Skapa dessutom en ny autentiseringslista med namnet *SSH-ACCESS* där endast användarnamnet (utan skiftlägeskänsligt läge, *local*) används för autentisering. Applicera denna lista där SSH är konfigurerat. Testa och verifiera att konfigurationen fungerar genom att sätta igång ”debug aaa authentication” och testa att logga in dels via konsolporten (standard-listan), och via SSH (listan *SSH-ACCESS*).

Nästa steg är att sätta igång AAA Authorization.

12. Se till att användare med högsta behörighetsnivån som loggar in via SSH kommer direkt till *privileged executive mode*. Bevisa med skärmbild som visar både inloggningsförsök samt debugging.

Med AAA Authorization kan vi även se till att användare kopplas till en viss parser view vid inloggning.

13. Skapa en användare som automatiskt hamnar i ”helpdesk”-view vid inloggning via Telnet. Bevisa med skärmbild som visar både inloggningsförsök samt debugging. Kör även kommandot show parser view efter inloggning

Vi har fortfarande bara lokala AAA-tjänster, och även om detta ger oss fler möjligheter måste vi implementera en central lösning för att utnyttja AAA fullt ut.

14. Installera WinRADIUS eller valfri RADIUS-mjukvara och ställ in din labbdators brandvägg på sådant sätt att nätverksenheten kan nå den via RADIUS-protokollet. Lägg till RADIUS-servern i routern och ändra listan *SSH-ACCESS* så att den nu går via RADIUS istället för den lokala användardatabasen. Testa och verifiera att användare i RADIUS-servern kan logga in via SSH. Inkludera även skärmbild på det lyckade inloggningsförsöket i RADIUS-servern

15. Det finns många fler delar i att säkra upp management-planet (t.ex. NTP, SNMP, etc.), ta reda på minst tre olika delar och implementera dessa i er nätverksmiljö. Avsluta med att köra igenom funktionen *AutoSecure* för att se vilka fler delar som finns att säkra upp i enheten.

16. Nationellt cybersäkerhetscenter har släppt en rapport om cybersäkerhet i Sverige där de listar de viktigaste 11 rekommenderade säkerhetsåtgärderna för organisationer. Vilka 11 punkter är detta? Beskriv även med två-tre meningar vad varje säkerhetsåtgärd innebär